الملف الثالث: وكيل (win_edrAgent) Windows — الشرح الكامل من الداخل

أولاً: ما هو الوكيل ولماذا هو محور النظام؟

الوكيل هو البرنامج الذي يعمل مباشرةً على الجهاز الذي نريد حمايته. إنه ليس مجرد أداة جمع بيانات؛ بل هو نقطة المراقبة الأمامية التي ترى كل ما يحدث على الجهاز قبل أن يصل أي خبر لأي مكان آخر. الوكيل مبني بلغة Go ويعمل كـ Windows Service — أي يبدأ تلقائياً مع تشغيل النظام، يعمل في الخلفية بصلاحيات SYSTEM، ولا يظهر في شريط المهام.

الوكيل مُركَّب من عدة مكوّنات داخلية تعمل معاً بشكل متوازٍ في goroutines منفصلة، ويتواصل كل منها عبر Go channels أو mutexes.

ثانياً: دورة حياة الوكيل من لحظة التشغيل

عندما يبدأ الوكيل لأول مرة على جهاز جديد، تمر بعدة مراحل متسلسلة دقيقة.

المرحلة الأولى: التهيئة والتحقق من التسجيل

تبدأ دالة `main` في `cmd/agent` بقراءة الإعدادات. الإعدادات لا تُقرأ من ملف YAML عادي — بل من Windows Registry في المفتاح `HKLM\SOFTWARE\EDR\Agent` . هذا الاختيار مقصود: ملفات YAML يمكن تعديلها من أي مستخدم، أما Registry فيمكن تطبيق ACLs (Access Control Lists) عليه لمنع أي مستخدم غير SYSTEM من قراءة أو تعديل بيانات الوكيل. إذا لم تكن هناك إعدادات في Registry (أي هذه أول مرة)، يبحث عن ملف `config.yaml` في مجلد البرنامج.

بعد قراءة الإعدادات، يتحقق الوكيل من التسجيل عبر دالة `enrollment.EnsureEnrolled()` . هذه الدالة تفحص: هل يوجد `agent_id` في الإعدادات؟ هل توجد شهادة رقمية صالحة؟ إذا لم يكن لديه هوية بعد، يُبادر بالتسجيل مع الخادم.

المرحلة الثانية: عملية التسجيل (First-Touch Provisioning)

التسجيل عملية دقيقة هندستها تتضمن:

الخطوة 1: يُولِّد الوكيل مفتاح RSA خاصاً (Private Key) محلياً على الجهاز، ثم يُنشئ طلب توقيع شهادة (CSR - Certificate Signing Request) يتضمن معرّف الجهاز (hardware_id) والاسم.

الخطوة 2: يُرسل للخادم: رمز التثبيت (installation token)، اسم الجهاز (hostname)، نوع نظام التشغيل وإصداره، hardware_id، معلومات المعالج والذاكرة، وبيانات الـ CSR.

الخطوة 3: الخادم يتحقق من رمز التثبيت، يُنشئ سجل الوكيل في قاعدة البيانات، ثم يُوقِّع الـ CSR بمفتاح CA الخاص بالمنصة ويُعيد الشهادة الموقَّعة مع شهادة CA.

الخطوة 4: الوكيل يحفظ الشهادة المُستلَمة في Registry المشفَّر. من الآن فصاعداً، يستخدم هذه الشهادة في كل اتصال (mTLS).

فلسفة التسجيل هذه تُسمى "First-Touch Provisioning" لأن الوكيل يحصل على هويته الأمنية الكاملة من أول اتصال ناجح. لا توجد مرحلة "انتظار موافقة المدير" — التحقق يتم آلياً عند التسجيل، وإذا كان رمز التثبيت صالحاً تُصدَر الشهادة فوراً وينشط الوكيل مباشرةً.

المرحلة الثالثة: التشغيل الكامل

بعد التسجيل الناجح، يستدعي الوكيل `agent.Start(ctx)` التي تُطلق كل المكوّنات بالترتيب:

1. **تهيئة الأمان:** يُطبّق ACLs على مجلد `C:\ProgramData\EDR` لحماية بياناته.
2. **تشغيل Batcher:** goroutine تجمع الأحداث في دُفعات.
3. **تشغيل Sender:** goroutine تُرسِل الدُّفعات للخادم.
4. **تشغيل Collectors:** ETW, WMI, Network, Registry, DNS, USB — كل منها goroutine مستقلة.
5. **الاتصال بـ gRPC:** يحاول الاتصال بالخادم. إذا فشل يبدأ Reconnector.
6. **تشغيل Heartbeat:** يُرسل نبضات قلب كل 30 ثانية.
7. **تشغيل Command Loop:** يستمع للأوامر القادمة من الخادم.
8. **تشغيل Queue Processor:** يُرسِل الأحداث المخزّنة محلياً عند عودة الاتصال.

ثالثاً: جامعات الأحداث (Collectors) — كيف يرى الوكيل كل شيء

ETW Collector — جوهر المراقبة

ETW (Event Tracing for Windows) هي تقنية مدمجة في نواة Windows تسمح بتسجيل أحداث النظام على مستوى الـ Kernel. الوكيل ينشئ جلسة ETW خاصة باسم "EDRKernelTrace" تستقبل أحداث ثلاثة أنواع:

- **أحداث العمليات:** كل عملية تبدأ أو تنتهي على الجهاز.
- **أحداث تحميل المكتبات:** كل DLL تُحمَّل في أي عملية.
- **أحداث الملفات (FileIO):** كل عملية إنشاء أو كتابة لملف.

الجزء المدهون في هذا الملف هو ملفا `etw_cgo.c` و `etw_cgo.h` اللذان يحتويان على كود C يستخدم Windows TDH API (Trace Data Helper) لفتح جلسة ETW ومعالجة الأحداث الواردة. عندما يصل حدث ETW، يُحوِّله كود C إلى هيكل بيانات بسيط (`ParsedProcessEvent` أو `ParsedImageLoadEvent` أو `ParsedFileIoEvent`)، ثم يستدعي دالة Go مُصدَّرة (عبر

`//export goProcessEvent`). بهذه الطريقة يتجنب الوكيل تعقيدات إدارة الذاكرة بين C وGo — كود C يعالج الحدث، يُحوّله، ثم يستدعي Go.

عندما يُطلق كود C الـ `goProcessEvent` callback ، تبدأ Go بمعالجة الحدث:

أولاً — الإثراء (Enrichment): الحدث الخام من ETW يحتوي فقط على PID. الوكيل يستدعي `getImagePath(pid)` و `getCmdLine(pid)` و `getPrivileges(pid)` باستخدام NtQueryInformationProcess وQueryFullProcessImageName لاستخراج المسار الكامل للملف التنفيذي، سطر الأوامر الكامل، واسم المستخدم ومستوى الصلاحية والـ integrity level. هذا ضروري لأن قواعد Sigma تحتاج هذه المعلومات للتطابق.

ثانياً — الفلترة: قبل إرسال الحدث، يتحقق الوكيل من قائمتين. الأولى قائمة ثابتة في الكود لعمليات Windows النظامية الموثوقة جداً (مثل conhost.exe, wmiprvse.exe, audiodg.exe) التي تُولِّد آلاف الأحداث الجماعية بدون أي قيمة أمنية. الثانية قائمة `ExcludeProcesses` من الإعدادات القابلة للتخصيص. هذا الفلتر يُقلّل حجم الأحداث بنسبة تصل لـ 70% دون خسارة أي إشارة أمنية.

ثالثاً — الاستجابة الآلية المحلية: للملفات، إذا كان الحدث لملف جديد في مجلدات حساسة (Temp، Desktop، Downloads)، يُحسب SHA-256 للملف ويُقارَن بقاعدة بيانات التوقيعات المحلية. إذا تطابق — يُحجَر الملف فوراً محلياً دون انتظار قرار من الخادم.

رابعاً — الإرسال: الحدث المُعالَج يُوضَع في `eventChan` — قناة Go بحجم 5000 حدث. إذا امتلأت القناة، ينتظر الوكيل 2 ثانية قبل الإسقاط (للأحداث عالية الأولوية كالعمليات) أو يُسقِط فوراً (للأحداث المنخفضة الأولوية كالملفات).

WMI Collector — المعلومات الشاملة

WMI (Windows Management Instrumentation) يُوفّر معلومات نظامية ثرية لا تتوفر عبر ETW. الوكيل يستخدم PowerShell (بوضع -NoProfile) لتنفيذ استعلامات WMI لجمع:

- قائمة الاتصالات الشبكية الحية (TCP connections مع PID المرتبط).
- معلومات محوّلات الشبكة.
- قائمة العمليات الحالية مع تفاصيلها.

الوكيل يستبعد استدعاءات PowerShell الخاصة به من أحداث ETW (لأنها ستُولِّد حلقة تغذية راجعة) وذلك عبر فحص `isSelfOrChildProcess()` .

Network Collector — مراقبة الاتصالات

يجمع معلومات TCP connections كل 30 ثانية باستخدام `Get-NetTCPConnection` . لكل اتصال يُسجَّل: العنوان المحلي والمنفذ، العنوان البعيد والمنفذ، الحالة (ESTABLISHED/LISTEN/etc)، والـ PID المرتبط به ومسار العملية.

Registry Collector — مراقبة السجل

يُراقب مفاتيح التشغيل التلقائي (Run Keys) ومفاتيح الخدمات للكشف عن آليات الثبات (Persistence) التي يستخدمها المهاجمون لضمان بقاء برامجهم بعد إعادة التشغيل.

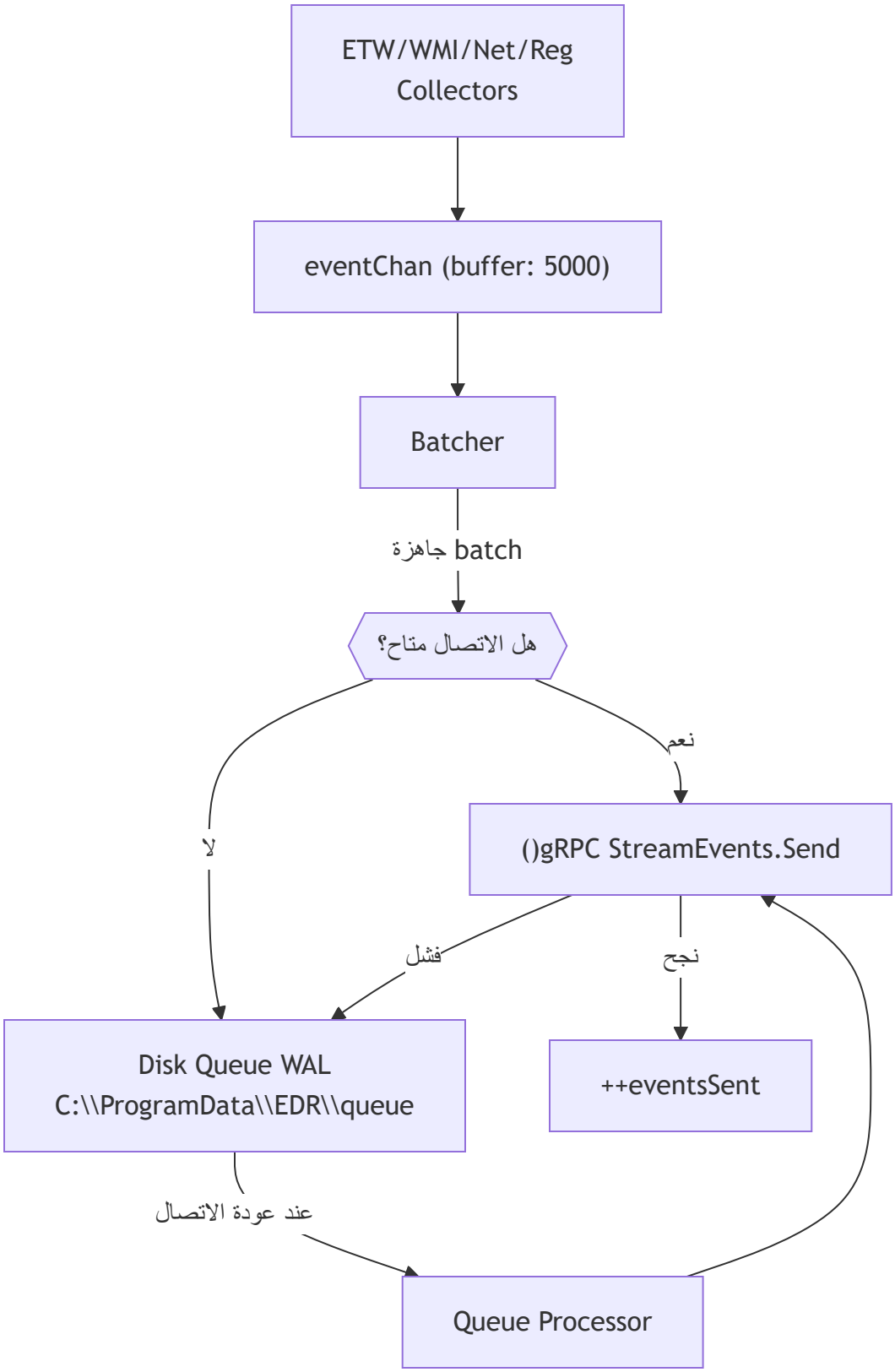
DNS Collector — مراقبة الاستعلامات

يُراقب استعلامات DNS لالتقاط أسماء النطاقات التي يتصل بها الجهاز. هذا مفيد لكشف الاتصال بـ C2 servers (خوادم التحكم التابعة للمهاجمين).

USB Watcher — مراقبة الأجهزة القابلة للإزالة

يُراقب إدخال وإخراج أجهزة USB باستخدام WMI Event Subscription. عند إدخال جهاز USB، يُسجَّل مساره كجذر مُراقَب في محرك الاستجابة (Responder Engine) حتى تخضع كل الملفات المنسوخة منه لفحص التوقيعات الفوري.

رابعاً: خط أنابيب معالجة الأحداث (Event Processing Pipeline)



الـ Batcher — لماذا لا نُرسِل كل حدث على حدة؟

إرسال كل حدث منفرداً سيعني آلاف استدعاءات gRPC في الدقيقة، مما سيُثقّل الشبكة والخادم. الـ Batcher يجمع الأحداث في دُفعات بحجم 100 حدث أو مهلة زمنية 5 ثوان (أيهما يأتي أولاً). ثم يُسلسِل الدُّفعة بـ Protobuf ويضغطها بـ Snappy. الضغط يُقلّل حجم البيانات بنسبة 60-80%.

Disk Queue — ضمان عدم فقدان الأحداث

القرص يعمل كـ Write-Ahead Log. عندما يفشل الإرسال عبر gRPC، يحفظ الوكيل الدُّفعة المُسلسَلة في ملف على القرص بمجلد `C:\ProgramData\EDR\queue` . حجمه الأقصى 500MB. عندما يعود الاتصال، يقرأ Queue Processor الملفات بالترتيب ويُرسلها مع Exponential Backoff (يبدأ بثانية، يتضاعف حتى 30 ثانية كحد أقصى).

خامساً: محرك الاستجابة الآلية (Responder Engine) — الحارس المحلي

محرك الاستجابة يعمل بجانب الـ ETW Collector. عندما يأتي حدث FileIO لملف في مجلد حساس:

1. يتحقق أن الملف ليس في قائمة الاستثناءات (الملفات التي أعادها المدير مؤخراً لها استثناء مؤقت 10 ثوان).
2. ينتظر 150ms ليضمن اكتمال كتابة الملف.
3. يُحسب SHA-256 للملف (بحد أقصى 10MB للفحص).
4. يُقارن الـ hash بقاعدة بيانات التوقيعات المحلية (`signatures.Store`).
5. إذا تطابق: يُنشئ مجلد الحجر `C:\ProgramData\EDR\quarantine` ، ينقل الملف إليه بصيغة `YYYYMMDD_HHMMSS_filename.quarantine` ، يكتب ملف `meta.` يتضمن المسار الأصلي والـ SHA256 واسم التهديد ووقت الحجر، ثم يُولِّد حدث `auto_quarantined` يُرسَل للخادم بأولوية عالية.

المجلدات المُراقَبة:

- `\Users\*\Downloads\`
- `\Users\*\Desktop\`
- `\AppData\Local\Temp\`
- `\ProgramData\`
- أجهزة USB المتصلة (مُضافة ديناميكياً)

سادساً: نظام إعادة التسجيل التلقائي (Auto Re-Enrollment)

هذا من أذكى أجزاء الوكيل. إذا رفض الخادم اتصال الوكيل برمز `Unauthenticated` (يعني الشهادة مُلغاة أو انتهت صلاحيتها)، تُطلَق آلية إعادة التسجيل الكاملة:

1. قطع الاتصال الحالي.
2. حذف الشهادة القديمة من الملفات والـ Registry.
3. مسح `agent_id` من الإعدادات (لإجبار إنشاء هوية جديدة).
4. استدعاء `EnsureEnrolled()` للحصول على شهادة جديدة.
5. إعادة الاتصال بالشهادة الجديدة وإعادة تشغيل Heartbeat.

هذا يعني أن الوكيل يستطيع إعادة تأهيل نفسه تلقائياً دون تدخل بشري — سواء بعد OS reinstall أو بعد إلغاء الشهادة من لوحة التحكم.

سابعاً: نبضات القلب (Heartbeat) — كيف يُخبر الخادم أنه حي

كل 30 ثانية يُرسل الوكيل حزمة Heartbeat تتضمن:

- حالته: Healthy أو Degraded أو Critical أو Isolated.
- مقاييس الأداء: CPU%، الذاكرة المستخدمة والإجمالية.
- مقاييس الأحداث: عدد الأحداث المُنتَجة، المُرسَلة، المُسقَطة.
- عدد الملفات في قائمة الانتظار على القرص.
- حالة Sysmon (هل مثبّت؟ هل يعمل؟).
- عناوين IP الحالية للجهاز.
- إصدار الوكيل.
- المستخدم الحالي المسجّل دخوله.

الخادم يرد بـ:

- هل هناك أوامر معلّقة تنتظر التنفيذ؟
- هل الشهادة تحتاج للتجديد؟
- هل هناك إعدادات جديدة يجب تطبيقها؟

حساب درجة الصحة: بناءً على هذه المقاييس، يحسب الخادم درجة صحة الوكيل (health_score) من 0 إلى 100 بصيغة مرجَّحة:

- 40% من جودة التوصيل: (أحداث مُرسَلة / أحداث مُنتَجة) × 100
- 30% من حالة الوكيل: Online=100، Degraded=80، Offline=50، Suspended=0
- 20% من معدل الإسقاط: إذا زاد عن 20% → 0 نقاط (مؤشر هجوم تعطيل)
- 10% من ضغط الموارد: إذا CPU أو RAM أعلى من 90% → طرح نقاط

ثامناً: نظام الأوامر (Command Handler) — تنفيذ الأوامر

عندما يصل أمر من الخادم، يُوضَع في `commandChan`. الـ Command Loop يستلمه ويُطلق goroutine جديدة لتنفيذه (حتى 8 goroutines متزامنة). عند الانتهاء، يُرسَل ناتج التنفيذ للخادم.

الأوامر المُنفَّذة محلياً تشمل:

- **isolate_network:** يُنشئ قواعد جدار حماية Windows بـ netsh تسمح فقط بالاتصال بـ IP الخادم على المنفذ 50051، وتمنع كل الاتصالات الأخرى.
- **terminate_process:** يُوقف عملية بـ PID أو اسمها.
- **quarantine_file:** يحجر ملفاً محدداً بمساره.
- **run_cmd:** يُنفّذ أمراً في PowerShell أو CMD ويُعيد المخرجات.
- **collect_logs:** يجمع سجلات Windows Event Log المحددة.
- **update_filter_policy:** يُحدِّث إعدادات الفلتر للوكيل.